Cont.

OR

echo 'password' | nc localhost 30000 →

netcat → tool for writing, reading and redirecting data across network ports

"nc localhost 30000" mean telling Netcat to open a direct, raw TCP connection to port 30000 on the current machine (localhost).

Level 15

SSL / TLS encryption.

↓

Secure Socket Layers → networking protocol enables devices to communicate using an encrypted connection.

TLS → Transport layer Security

SSL/TLS used to provide encrypted communication with networking protocols.

OpenSSL s_client -quiet -connect localhost:30001

("password" → input)

Secure Client module.

↓

Level 16

This makes tool exactly like Netcat, but forces to secure a SSL/TLS connection.

Network mapper → standard tool for network discovery.

(1) nmap -p 31000-32000 -sV localhost

I will scan 1000 ports, and print ones that are open. Look for ports ssl/echo or ssl/unknown.

I got 31170 → 31289 → RSA key

(1) copied
(2) chmod 600
(3) ssh -i " " bandit17@...

Level 17

(1) diff passwords.old passwords.new

we get difference in contents of files → password *

Level 18

ssh bandit18@band.... .org "cat readme"

Instead of logging it and getting logged out, ssh connects & instantly reads the file. & prints the password.

Level 19

Set owner User ID

mos-- when a file has a SUID bit(s)

it temporarily executes with the permissions of the person who created it.

→ bandit20-do is owned by bandit20. and has s bit, running it temporarily grants you bandit20 powers

simply cat /etc/bandit-pass/bandit20

↳ Permission Denied

can only be read by owner.

So, if we know the SUID script, we can steal passwords from the server.

↳ just like (bandit20-do)

• ./bandit20-do cat /etc/bandit_pass/bandit20.

↓

Level 20

SUID → Netcat used for the server to listen to our password.

(1) nc -l -p. "____" → random port (1024 ≤ x ≤ 65535)

(2) ./suconnect "port"

↓

Password input

↓

we get the password back.

0 – 1023 → used by system

1024 – 65535 → can be used by us.

↓

Level 21

Cronjob 22 in /etc/.cron.d.

↓

• cat /etc/cron.d/cronjob_bandit22

↓

cat /tmp/bandit22 → whoami

↓

Level 22

↓

Hashing . md5sum cogic

target= echo "I am user bandit23 | md5sum | cat /tmp/hash"

↓

we get a target

↓

Password file cat /tmp/"target we got"

↓

Level 23

Script building

bandit24 crontjob.

/tmp ; chmod +x ;

cp to /var/spool/bandit24/foo.

↓

Level 24

Brute forcing 10000 combinations

brute forcing

for i in {0000...9999}; do echo "$pass $i" done. | nc localhost 30002 | grep -v "Wrong!"

connecting to server.

ignore wrong ones